

Projeto Integrador de Tecnologia da Informação III

Prof. Dr. Hudson Silva Borges

Módulo 3 – Boas práticas em serviços web

Unidade 1 - Desenvolvimento seguro

Desenvolvimento **seguro**

- Construir software seguro exige ter o conhecimento básico dos **princípios de segurança**.
- **Objetivo:** manter a confidencialidade, integridade e disponibilidade dos recursos de informação para permitir operações bem sucedidas.
- **Como alcançar:** implementação de controles de segurança.

Desenvolvimento **seguro**

- Princípios de segurança podem ser aplicados em **diversas camadas** de diferentes plataformas e domínios.
- Contém controles técnicos para **mitigar ocorrências** de vulnerabilidades mais comuns de software.
- Busca proteger o negócio **contra riscos inaceitáveis**.

Princípios gerais

- O que é um risco?

Um *agente de ameaça* interage com um *sistema*, no qual pode haver uma *vulnerabilidade latente* que pode ser *explorada* e causar um *impacto*.

- **Exemplo:**

Um ladrão de carros (*agente de ameaça*) passa por um estacionamento de carros verificando nos carros presentes (*o sistema*) procurando por portas destrancadas (*a vulnerabilidade*) e quando a encontra, abre a porta (*a exploração*) e leva para si o que está dentro do carro (*o impacto*).

Princípios gerais

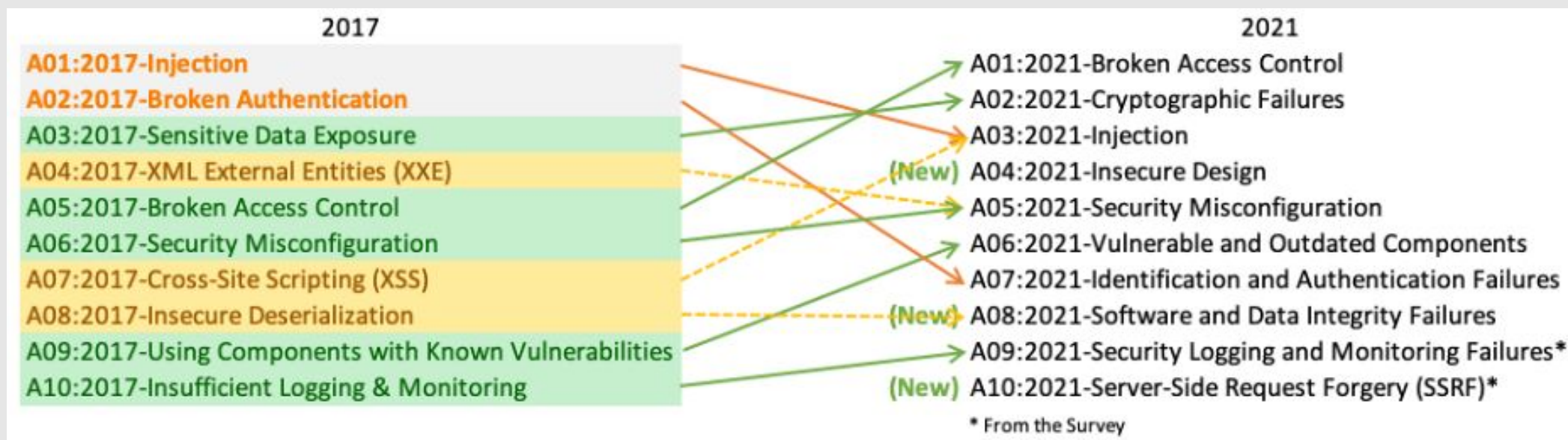
- Elementos adicionais precisam ser integrados no desenvolvimento.
- São requisitos de segurança e casos de abuso.
- Guias podem ser elaborados para ajudar na identificação e abordagem de requisitos e cenários de ataques.
- Na *web*, controles no cliente oferecem pouco ou nenhum benefício de segurança.

- Falhas de segurança de *software* podem ser introduzidas em qualquer fase do ciclo de desenvolvimento:
 - Não identificação das necessidades no início;
 - Arquiteturas com problemas;
 - Práticas de codificação ruins;
 - Implantação de modo inadequado;
 - Inserção durante manutenções.

Camadas de segurança

- Infraestrutura;
- Aplicação;
- *Log e auditing;*
- Ferramentas;
- Ambientes;
- Equipe;
- API;
- *Error e exceções.*

Top-10 riscos do OWASP



Fonte: [OWASP Top 10](#)

* Uma nova versão está prevista para 2025

Recomendações - Infraestrutura

- Usar *criptografia* nos dados;
- Proteger ambientes internos;
- Não usar componentes com vulnerabilidades conhecidas (CVEs);
- Outros.

Recomendações - aplicação

- Usar bibliotecas atualizadas;
- Considerar autenticação de múltiplos fatores;
- Cuidado no armazenamento e compartilhamento de senhas;
- Criar política de senhas;
- Proteger contra requisições exaustivas;
- Fazer gestão efetiva da sessão de usuário.

Recomendações - *log e auditing*

- Monitoramento e resposta a incidentes;
- Manter registros de acessos de usuários;
- Rastreabilidade de ações/operações.

Recomendações - ferramentas

- Usar ferramentas de testes de segurança;
- Executar processos externos;
- Realizar versionamento de projeto e código.

Recomendações - API

- Adotar verificações de autorização;
- Evitar expor dados em excesso;
- Tratar adequadamente dados das requisições;
- Proteger contra ataques força-bruta;
- Configurar adequadamente componentes e recursos;
- Outros.

Recomendações - OWASP



Fonte: <https://cheatsheetseries.owasp.org/>

Módulo 3 | Unidade 1

Desenvolvimento Seguro

Visão integradora aplicada



AGEAD

Agência de Educação
Digital e a Distância

Por onde começar?

- Incorpore práticas de desenvolvimento seguro desde a concepção do projeto.
- Defina os requisitos de segurança no início.
- Faça revisões e auditorias no projeto/código.
- Faça testes de segurança.
- Use ferramentas automatizadas.

Próxima unidade



Unidade 2 - Documentação e versionamento de serviços

Referências

NETO, Tarcizio Vieira. **Modelo de processo para desenvolvimento de aplicações seguras**. Disponível em: <https://link.ufms.br/nsb26>. Acesso em: 22 nov. 2024.

OWASP FOUNDATION. **OWASP Top Ten 2021**. Disponível em: <https://link.ufms.br/x0AMA>. Acesso em: 12 fev. 2025.

OWASP FOUNDATION. **Security Fundamentals**. Disponível em: <https://link.ufms.br/nbl2h>. Acesso em: 12 fev. 2025.

Licenciamento



Respeitadas as formas de citação formal de autores de acordo com as normas da ABNT NBR 6023 (2018), a não ser que esteja indicado de outra forma, todo material desta apresentação está licenciado sob uma [Licença Creative Commons - Atribuição 4.0 Internacional](https://creativecommons.org/licenses/by/4.0/).

